



# Hạ tầng Thanh toán điện tử & An toàn thông tin TMĐT

Chương 1 - Tiết 5 | Quản trị tác nghiệp Thương mại điện tử

Thực hiện: Trần Thành Thắng  
Lớp: Quản trị kinh doanh BA24M



# Tổng quan & Mục tiêu bài giảng

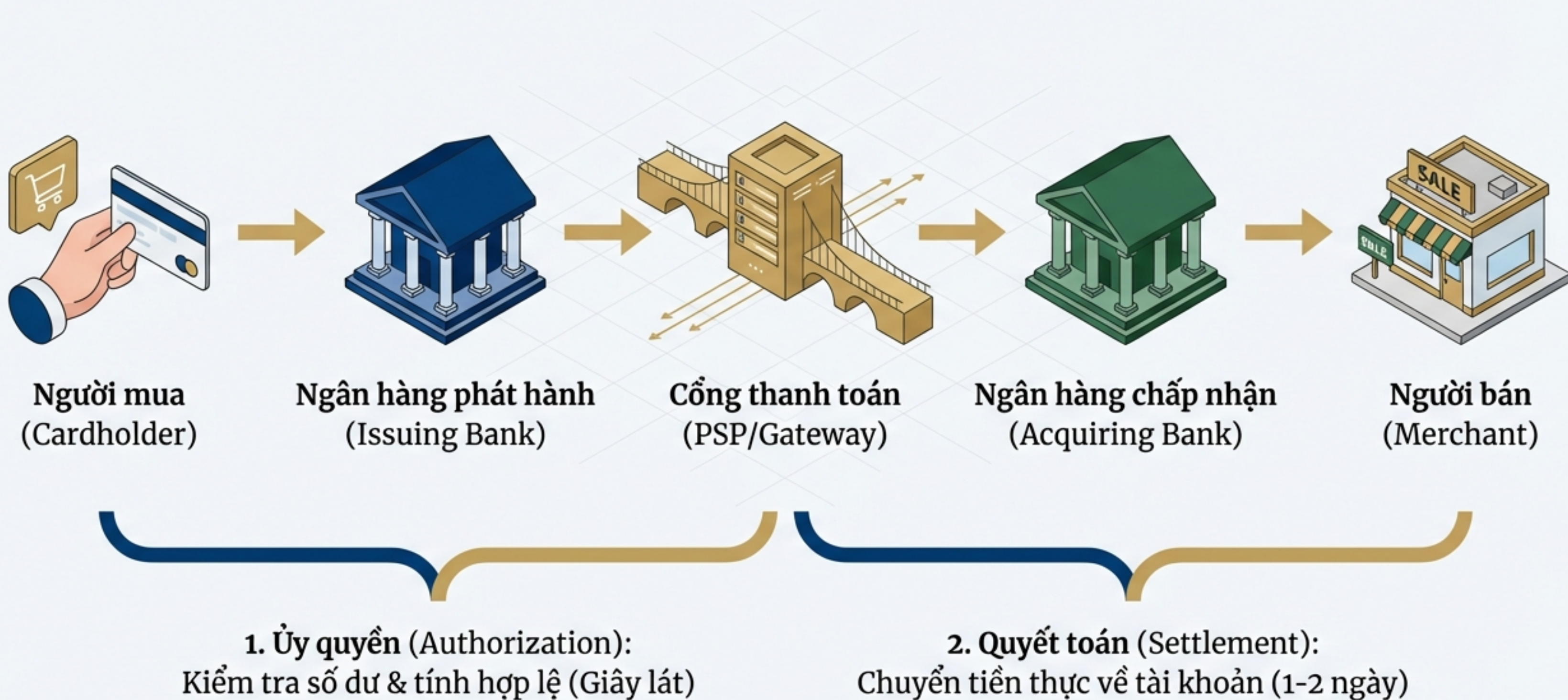
**Vị trí bài học:** Tiếp nối nội dung Tổng quan về Thương mại điện tử.

- Hiểu cơ chế vận hành dòng chảy tiền tệ: Thẻ, Ví điện tử, Cổng thanh toán.
- Nắm vững cơ chế phòng vệ: Mô hình CIA & Các phương thức an ninh mạng cơ bản.

**Thông điệp quản trị:** Không có thanh toán = Không có doanh thu.  
Không có bảo mật = Không có niềm tin.



# Hệ sinh thái Thanh toán thẻ trực tuyến



# Các phương thức thanh toán hiện đại

## Thẻ thông minh (Smart Cards)



- Sử dụng chip vi xử lý (tiêu chuẩn EMV) để tăng bảo mật.
- Contactless (Không tiếp xúc): Công nghệ NFC, chạm để thanh toán.

## Ví điện tử (Digital Wallets)



- Dựa trên thiết bị (Hardware-based): Apple Pay, Samsung Pay.
- Dựa trên đám mây (Cloud-based): PayPal, Alipay (QR Code).

## Thanh toán siêu nhỏ (Micropayments)



- Giao dịch giá trị thấp (<\$10) như nhạc, game.
- Giải pháp: Gom hóa đơn (Aggregation) hoặc trừ tài khoản viễn thông.

# Cổng thanh toán trung gian: PayPal & Alipay



## Vai trò cốt lõi:

- **Bảo vệ thông tin:** Người mua không lộ tài khoản cho người bán.
- **Cơ chế Escrow (Ký quỹ):** Tiền được giữ tại trung gian -> Người mua nhận hàng -> Tiền chuyển cho người bán.

## Lợi ích cho SME (Doanh nghiệp vừa và nhỏ):

- **Tích hợp dễ dàng,** không cần hạ tầng ngân hàng phức tạp.
- **Tăng tỷ lệ chốt đơn** (Conversion rate) & Niềm tin.

# Chiến lược An toàn thông tin: Tam giác CIA

Confidentiality (Tính bảo mật): Chỉ người có quyền mới được xem dữ liệu (VD: Mã hóa số thẻ).



**C - Confidentiality**



**A - Availability**



Availability (Tính sẵn sàng): Hệ thống luôn hoạt động (Uptime) khi khách cần.



**I - Integrity**



Integrity (Tính toàn vẹn): Dữ liệu không bị thay đổi trái phép trên đường truyền.

Khái niệm mở rộng:  
Non-repudiation  
(Không thể chối bỏ)  
- Đảm bảo các bên không thể phủ nhận hành động đã thực hiện.

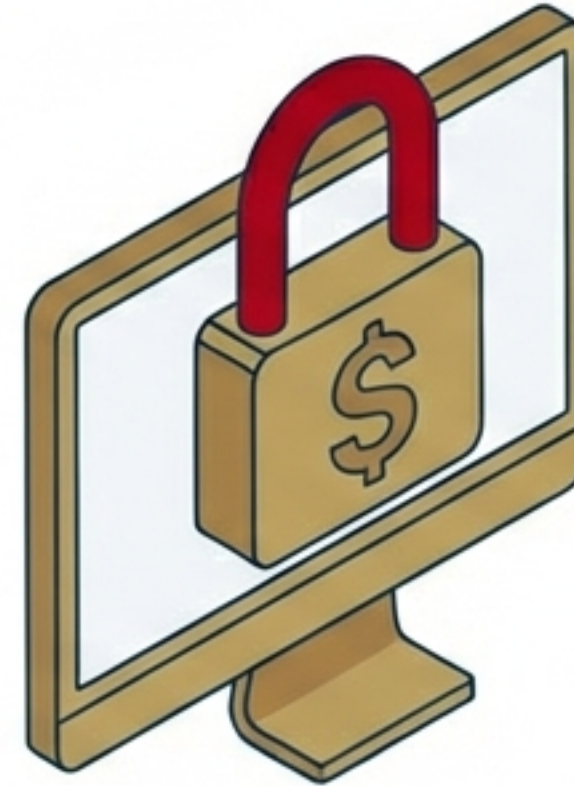
# Mối đe dọa kỹ thuật: Kẻ thù vô hình

## Mã độc (Malware)



- Virus/Worms: Tự nhân bản và phá hoại hệ thống.
- Trojan Horse: Ngụy trang phần mềm lành tính để trộm tin.
- Botnets: Mạng lưới máy tính 'ma' (Zombies) dùng tấn công quy mô lớn.

## Ransomware (Mã độc tống tiền)



- Cơ chế: Mã hóa toàn bộ dữ liệu người dùng.
- Hậu quả: Hacker đòi tiền chuộc (thường là Bitcoin) để mở khóa.
- Đánh giá: Mối nguy hiểm lớn nhất hiện nay.

# Tấn công phi kỹ thuật: Yếu tố con người



## Social Engineering (Kỹ nghệ xã hội):

Hack “con người” thay vì hack “máy móc”.

## Phishing (Lừa đảo giả mạo):

- Gửi email/tin nhắn giả danh ngân hàng, sàn TMĐT.
- Mục tiêu: Dụ người dùng nhập mật khẩu vào **website giả**.

## Gian lận thẻ (Card Fraud):

- Sử dụng thông tin thẻ bị đánh cắp.
- Rủi ro: Người bán chịu thiệt hại do **Chargeback (Truy hồi tiền)**.

# Tấn công Từ chối dịch vụ (DoS/DDoS)



## Cơ chế:

- Huy động Botnet gửi hàng triệu yêu cầu truy cập cùng lúc.

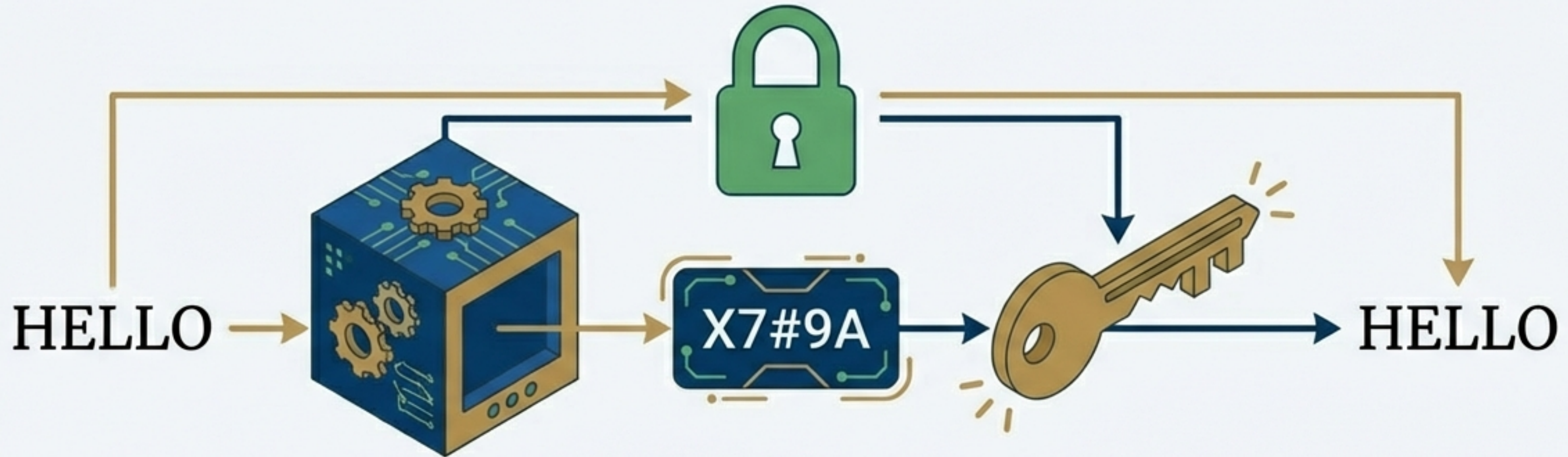
## Mục tiêu:

- Làm sập hệ thống -> Vi phạm tính Availability (Sẵn sàng).

## Case Study: Vụ tấn công Dyn (2016)

- Hacker sử dụng thiết bị IoT (Camera, Tủ lạnh thông minh) để tạo Botnet.
- Hậu quả: Đánh sập Twitter, Netflix, Reddit trên diện rộng.

# Hệ thống phòng thủ: Mã hóa dữ liệu



## Mã hóa (Encryption):

Biến dữ liệu thành dạng "không thể đọc" nếu thiếu khóa.

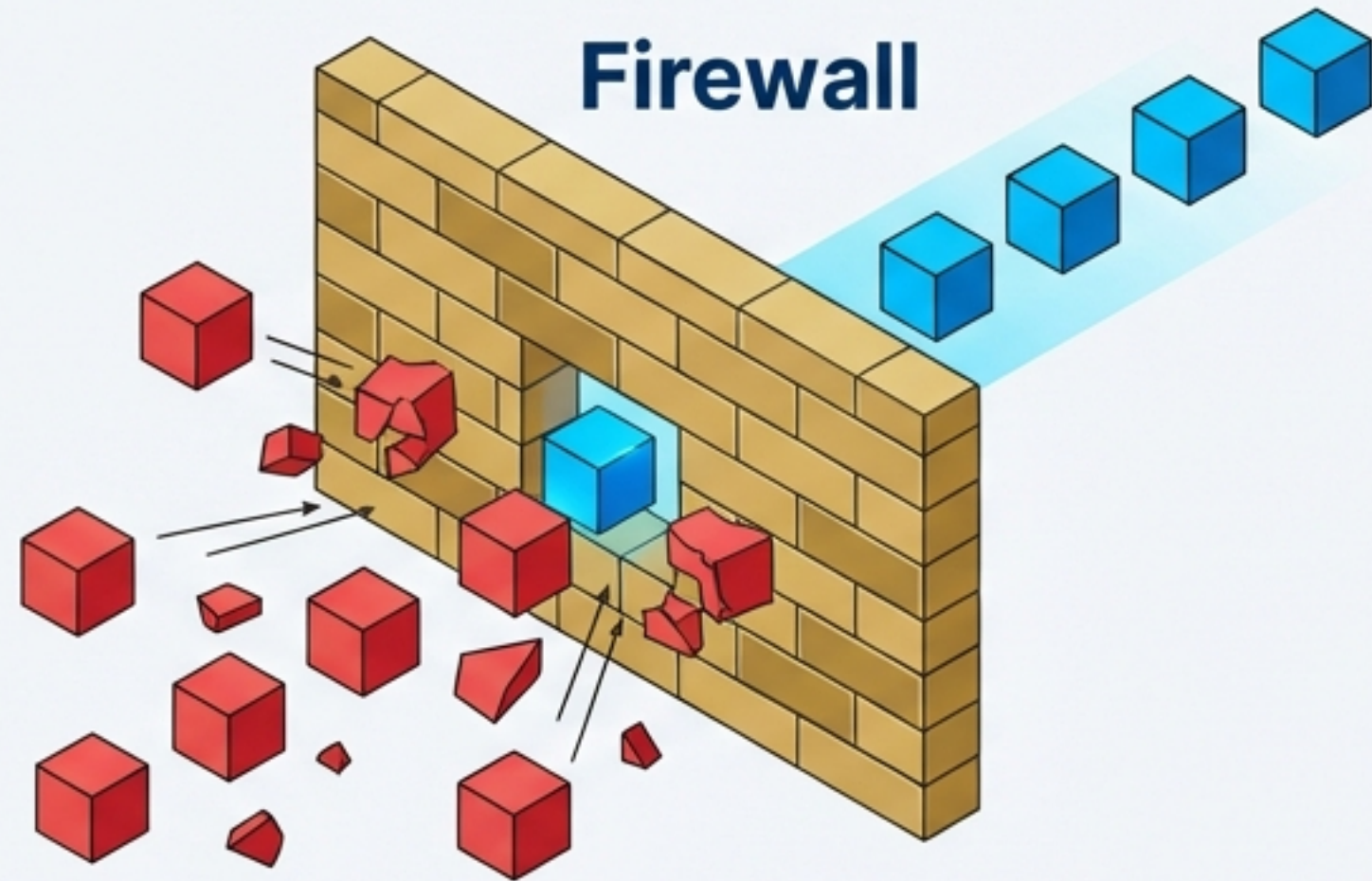
## Giao thức SSL/TLS:

- Bảo vệ đường truyền thanh toán.
- Dấu hiệu:  khóa xanh + "https://" trên trình duyệt.

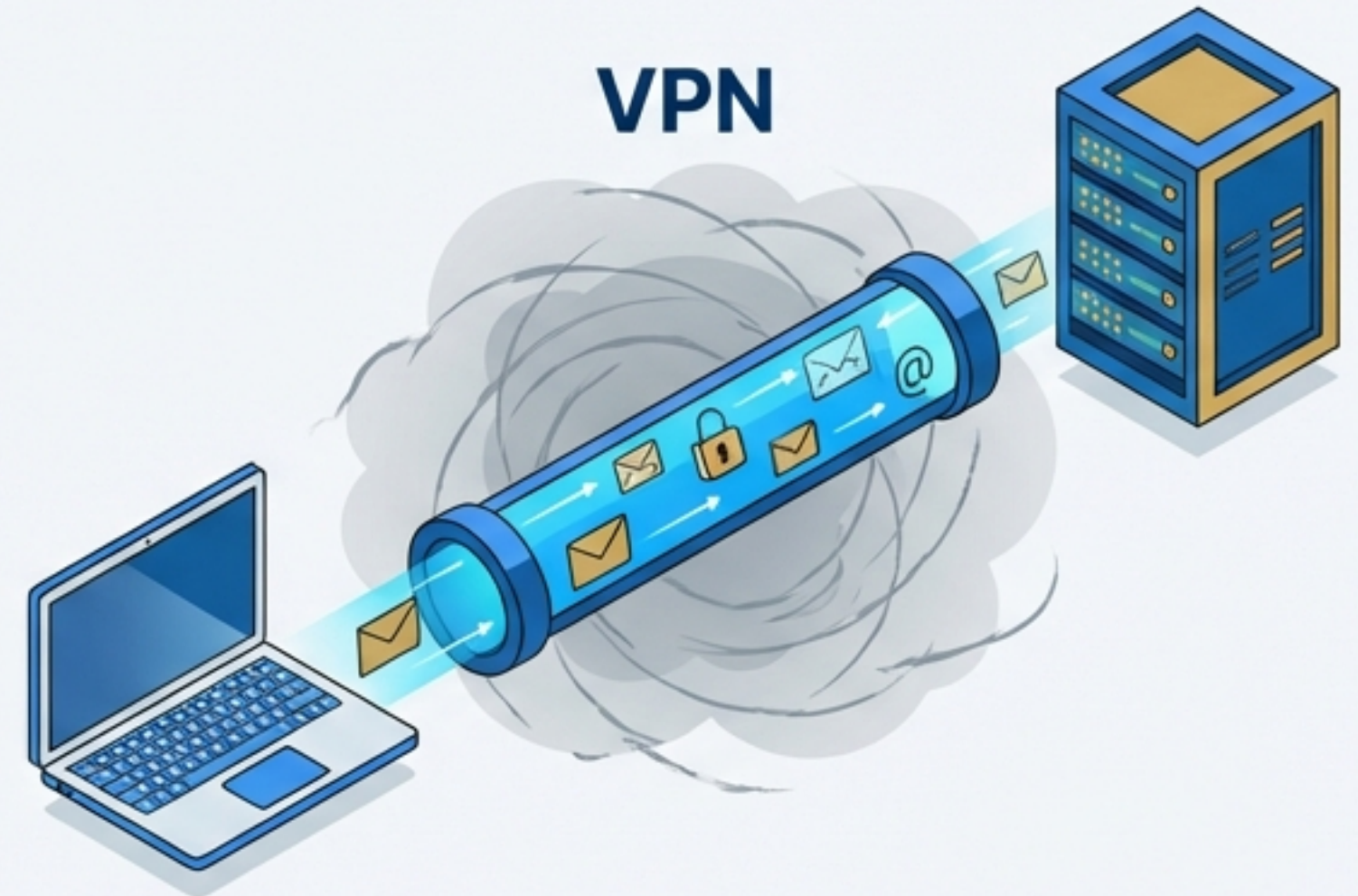
## PKI (Hạ tầng khóa công khai):

- Sử dụng cặp khóa (Public/Private Key).
- Ứng dụng Chữ ký số để xác thực danh tính.

# Phòng thủ tổ chức: Tường lửa & VPN



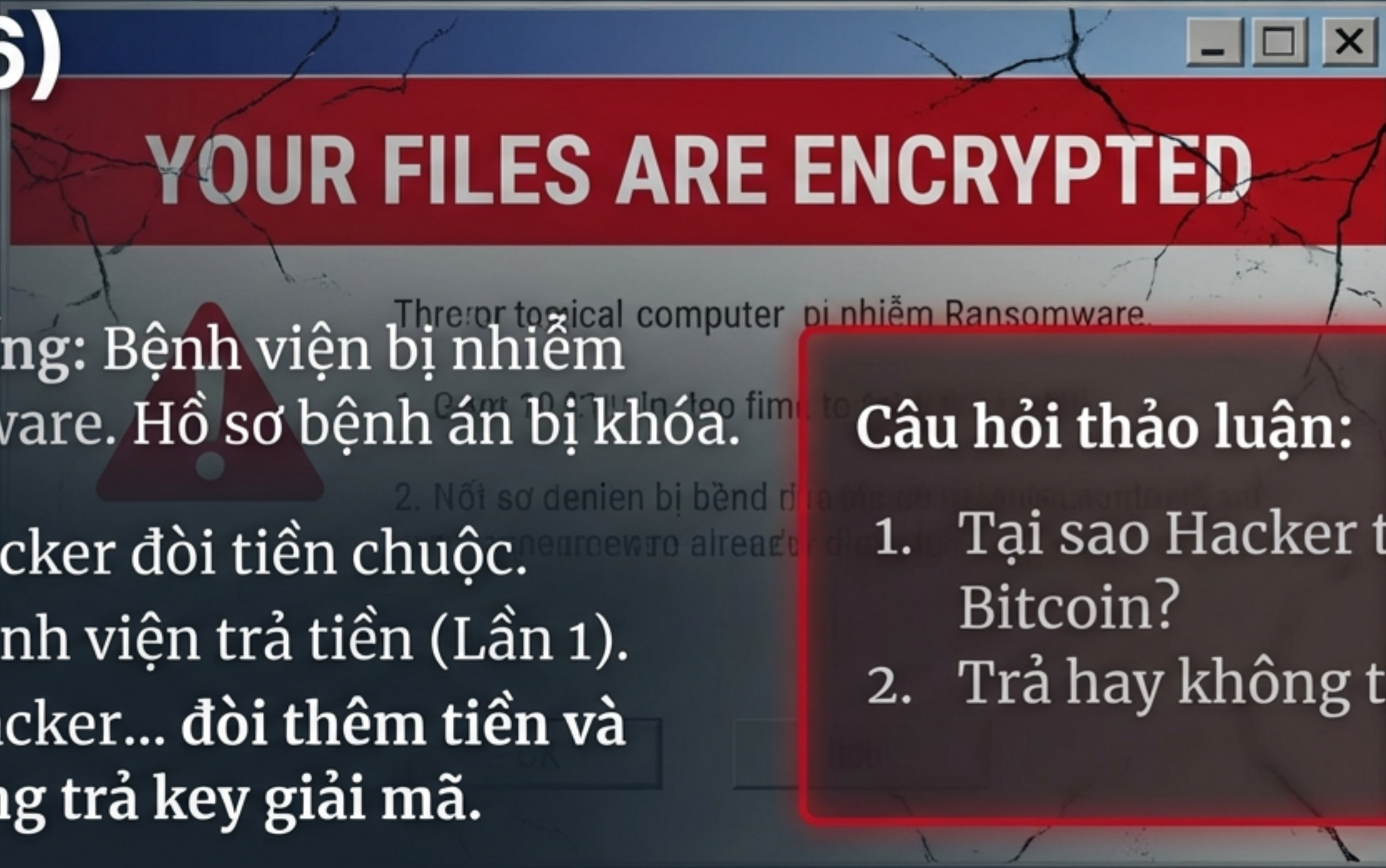
**Tường lửa (Firewall):** Người gác cổng. Kiểm soát luồng tin ra/vào, chặn truy cập trái phép.



**VPN (Mạng riêng ảo):** Đường hầm bảo mật. Giúp nhân viên làm việc từ xa an toàn.

**Lưu ý quản trị:** Công nghệ chỉ là công cụ. Chính sách và đào tạo nhân sự mới là then chốt.

# Case Study: Sự cố Bệnh viện Tim Kansas (2016)



**YOUR FILES ARE ENCRYPTED**

**Tình huống:** Bệnh viện bị nhiễm Ransomware. Hồ sơ bệnh án bị khóa.

- 1. Hacker đòi tiền chuộc.
- 2. Bệnh viện trả tiền (Lần 1).
- 3. Hacker... đòi thêm tiền và không trả key giải mã.

**Câu hỏi thảo luận:**

- 1. Tại sao Hacker thích Bitcoin?
- 2. Trả hay không trả?

# Bài học quản trị từ Case Study

## Phân tích



Tại sao Bitcoin? Tính ẩn danh, khó truy vết.



**Chiến lược ứng phó:** KHÔNG TRẢ. Trả tiền không đảm bảo lấy lại dữ liệu và khuyến khích tội phạm.

## Lỗi hổng & Giải pháp

**Lỗi hổng quản trị** (Root Causes):



- Thất bại trong Backup (Sao lưu): Thiếu bản sao lưu offline.



- Thiếu đào tạo nhân viên: Sự cố bắt nguồn từ Phishing/Email lạ.

# Tổng kết & Hỏi đáp



Thanh toán điện tử cần sự tiện lợi nhưng phải an toàn.  
Bảo mật là cuộc đua không hồi kết giữa ‘khiên’ và ‘giáo’.

**Q & A**